

PRÁCTICA DE LABORATORIO 10

Investigar 3 ataques famosos de ingeniería social.

El hackeo de RSA Security – 2011

Responder:

¿Qué técnica se usó?

Utilizaron Spear Phishing. Los atacantes enviaron a un pequeño grupo de empleados un correo titulado "2011 Recruitment plan" con un archivo Excel adjunto que contenía un exploit de día cero en Adobe Flash. Al abrirlo, se instaló una puerta trasera que permitió a los atacantes moverse dentro de la red corporativa.

¿Qué emociones explotaron los atacantes?

- Curiosidad: un tema laboral relevante y creíble
- Confianza: parecía un correo interno de Recursos Humanos
- Rutina laboral: apertura de adjuntos como parte del trabajo diario

¿Qué consecuencias tuvo?

Los atacantes lograron robar información relacionada con los algoritmos y semillas (seeds) de los tokens SecurID de RSA. Esto obligó a la empresa a reemplazar aproximadamente 40 millones de tokens en todo el mundo y derivó en ataques posteriores contra sus clientes, incluyendo contratistas de defensa como Lockheed Martin.

¿Cómo se pudo haber evitado?

- Filtros avanzados contra archivos adjuntos maliciosos
- Actualización oportuna de software vulnerable (parches de día cero)
- Capacitación en identificación de correos sospechosos
- Segmentación de red para limitar el movimiento lateral

Target – 2013

Responder:

¿Qué técnica se usó?

Utilizaron Phishing dirigido a un tercero. Los atacantes enviaron un correo con malware a un proveedor externo de aire acondicionado (Fazio Mechanical) que tenía acceso remoto a la red de Target, y usaron esas credenciales robadas para infiltrarse en los sistemas de la tienda.

¿Qué emociones explotaron los atacantes?

- Confianza: aprovecharon la relación proveedor-cliente
- Descuido: falta de sospecha ante un correo aparentemente normal
- Rutina laboral: uso habitual del acceso remoto del proveedor

¿Qué consecuencias tuvo?

Se robaron los datos de aproximadamente 40 millones de tarjetas de crédito y débito, además de información personal de unos 70 millones de clientes. Target enfrentó pérdidas superiores a los 200 millones de dólares en multas, demandas y costos de remediación, así como un fuerte daño reputacional.

¿Cómo se pudo haber evitado?

- Segmentación de red entre proveedores y sistemas de pago

- Monitoreo y control de accesos de terceros
- Autenticación multifactor para accesos remotos
- Detección temprana de tráfico anómalo en la red

MGM Resorts International – 2023

Responder:

¿Qué técnica se usó?

Utilizaron Vishing combinado con suplantación de identidad. El grupo de atacantes (conocido como Scattered Spider) investigó en LinkedIn a un empleado de MGM y llamó al Help Desk de TI haciéndose pasar por él, logrando que le restablecieran las credenciales de acceso sin verificación adicional.

¿Qué emociones explotaron los atacantes?

- Confianza: se hicieron pasar por un empleado real
- Empatía: apelaron a la disposición del soporte técnico a ayudar
- Urgencia: solicitaron una solución rápida al "problema de acceso"

¿Qué consecuencias tuvo?

El ataque paralizó los sistemas de reservas, cajeros automáticos, tarjetas de acceso a habitaciones y máquinas tragamonedas en varios casinos y hoteles de MGM durante días. La empresa estimó pérdidas superiores a los 100 millones de dólares, además de la exposición de datos personales de clientes.

¿Cómo se pudo haber evitado?

- Protocolos estrictos de verificación de identidad en el Help Desk
- Autenticación multifactor resistente a ingeniería social
- Capacitación específica para personal de soporte técnico
- Planes de respuesta a incidentes probados con anticipación